

Code Sentry - Assignment 6 Evaluation Report

1. Correctness

The model reliably triggers `scan_vulnerabilities` on risky snippets and skips it on clean ones. This is achieved by utilizing the google-genai SDK's automatic function calling (AFC) within the `client.chats.create` method. The system prompt explicitly instructs the LLM to evaluate the code and use the tool. The tool itself gracefully returns an empty list for clean code, which the LLM correctly interprets as safe, fulfilling the core assignment loop.

2. Quality of vulnerability detection logic and clarity

The local `scan_vulnerabilities` tool uses targeted heuristics (Regex) to detect all assignment requirements, including hardcoded secrets, SQL injection (f-strings and format), insecure deserialization, dangerous subprocess calls (`shell=True`), and weak hashing (MD5/SHA1). The LLM takes these raw findings and enriches them by generating clear, developer-friendly explanations and actionable, secure code fixes.

3. Code organization and readability

The codebase is strictly organized according to the required project structure. `main.py` handles the LLM interaction and retry logic. `tools.py` is isolated, purely functional, and highly testable independent of the LLM. `prompts.py` separates the AI instructions from the execution logic. `tests/test_tools.py` provides standalone unit tests. The code is documented with standard Python docstrings and comments.

4. Robustness (error handling, edge cases)

Robustness is prioritized at both the tool and API levels. The `scan_vulnerabilities` tool processes code line-by-line and safely handles empty or malformed strings without crashing. On the networking side, the API integration in `main.py` includes an exponential backoff retry loop (with a try-except block) to gracefully handle 503 UNAVAILABLE or rate-limit errors from the Gemini API, ensuring the script does not crash during high-demand periods.

5. Clarity of the README and stated assumptions

The `README.md` provides crystal-clear setup instructions (including required pip installs and environment variables), execution commands for both the app and the unit test suite, and a full sample input/output demonstration. It clearly states the assumptions made, such as relying on the

Code Sentry - Assignment 6 Evaluation Report

newest google-genai SDK's Chat API for function calling and the addition of the retry mechanism.

6. Deliverables Provided

- Source code repository: The complete source code is bundled within the 'code_sentry' directory, ready to be initialized as a Git repository or compressed into a zipped folder for final submission.
- README.md: A comprehensive README is included at the project root. It explicitly covers the prerequisites, setup instructions, execution commands, a full example of input/output, and stated assumptions.
- Short Demo: A self-contained demo is built directly into main.py. Running 'python main.py' automatically submits a sample code snippet (containing command injection and weak hashing vulnerabilities) along with a natural language query. This showcases the end-to-end AI-powered analysis. The output of this demo is also documented inside the README.